420-D04-AB — Conformity Assessment

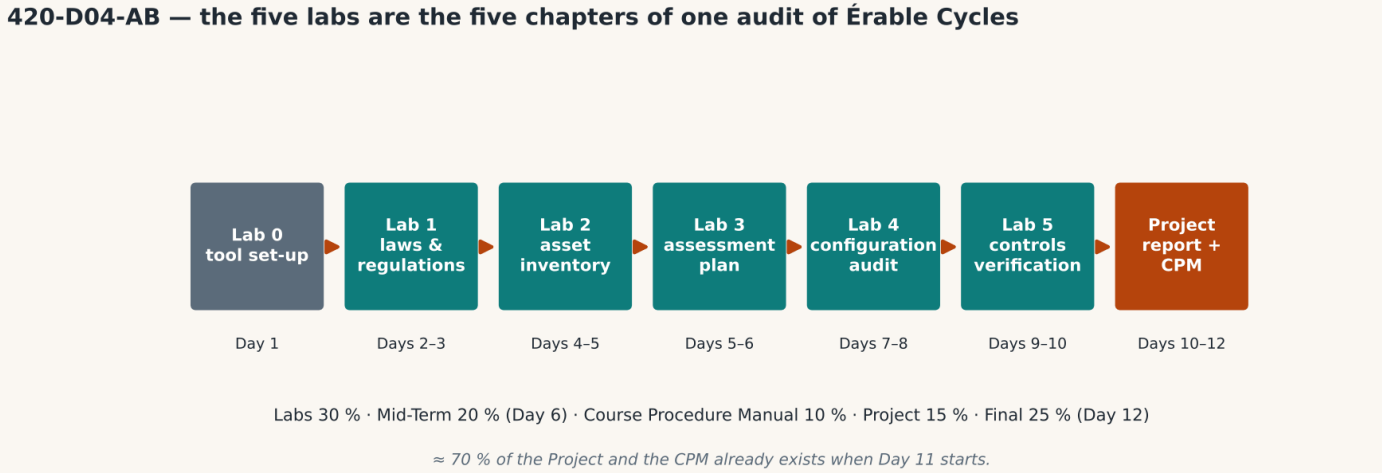
Day 1 — Introduction to Conformity Assessment
Cohort CYB-01 · Fall 2026 · Tuesday, October 27, 2026
Cyber.SoHo Educational Hub

Tonight's agenda

- 18:30–18:45 — Welcome, course map, the case company, ethics & legal notice
- 18:45–18:55 — Lesson 1 — Definition and objectives of conformity assessment
- 18:55–19:03 — Lesson 2 — Why conformity assessment matters in cybersecurity management
- 19:03–19:13 — Lesson 3 — Types of audits and assessments
- 19:13–19:21 — Lesson 4 — The role of conformity assessment in continuous improvement
- 19:21–19:30 — Lesson 5 — The six steps of an assessment plan
- 19:30–19:45 — Short break
- 19:45–19:55 — Lesson 6 — The case, the tool map and what Lab 0 will do
- 19:55–22:00 — Lab 0 — Install & verify the auditing tools (guided, then individual)

The course in one picture

- Five labs = five chapters of ONE audit of Érable Cycles inc.
- Lab 1 laws → Lab 2 assets → Lab 3 plan → Lab 4 configurations → Lab 5 controls
- Project (15 %) = the conclusion; Course Procedure Manual (10 %) = how it was done
- ≈ 70 % of both documents already exists when Day 11 starts



Evaluation plan

- Hands-on labs (5 × 6 %) — 30 % (EZ04 elements 1–5)
- Mid-Term Exam — Day 6, Tue Nov 10 — 20 % (elements 1–4 · 25 MCQ + 15 MSQ, 90 min)
- Course Procedure Manual — Day 12 — 10 % (elements 1–5)
- Project — Conformity Assessment Report — Day 12 — 15 % (elements 1–5)
- Final Exam — Day 12, Tue Nov 24 — 25 % (elements 1–5 · 25 MCQ + 15 MSQ, 90 min)

Legal notice and acceptable use — read before any tool runs

- Authorized targets only: your two lab VMs and the fictional case file — never college, employer, home or third-party systems
- Written mandate: the course mandate (Labs 0–2) and the CEO authorization letter you sign in Lab 3 — no mandate, no test
- The law: Criminal Code s. 342.1 and s. 430(1.1); 18 U.S.C. § 1030; EU Directive 2013/40/EU; Ley Orgánica 10/1995
- Confidentiality: mask real personal information in evidence; reports go only to the instructor through the LMS
- Professional ethics: the seven ISO 19011 principles; an honest “not tested” is fine, an invented result is misconduct
- Tool hygiene: official downloads only; VMs on an isolated (host-only / NAT) network
- Academic integrity (IPESA Policy No. 7, Policy 13) · late work −10 % per calendar day · e-signature form provided separately

1

Lesson 1 — Definition and objectives of conformity assessment

What a conformity assessment is, the vocabulary every auditor uses, and the three results an assessment must deliver.
≈ 10 minutes

Lesson 1 — Definition and objectives

- Conformity assessment = demonstration that specified requirements are fulfilled (ISO/IEC 17000:2020)
- Demonstration · specified requirements · fulfilled
- Evidence, not opinion; a written reference before the test

KEY TERM

Conformity assessment

Demonstration that specified requirements are fulfilled (ISO/IEC 17000:2020): a structured, evidence-based comparison between what is required and what actually exists.

Where requirements come from

- Laws & regulations — PIPEDA, Law 25, GDPR, CASL
- Contracts — PCI DSS through the merchant agreement
- Voluntary standards & frameworks — ISO/IEC 27001, NIST CSF 2.0, CIS Controls
- Internal policies — AUP, Patch Management Procedure

KEY TERM

Requirement

A need or expectation that is stated, generally implied or obligatory; it comes from a law, a contract, a standard or an internal policy.

The four functions (ISO/IEC 17000)

- Selection — what to examine and how
- Determination — collect information (document, interview, test)
- Review and attestation — compare and issue the result
- Surveillance — repeat over time

KEY TERM

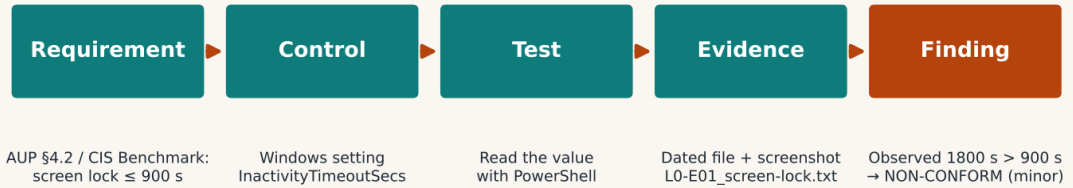
Control

A measure that maintains or modifies risk; the technical setting, procedure or practice intended to satisfy a requirement.

The assessment chain

- Requirement → control → test → evidence → finding
- Requirement: laptops lock after 15 min
- Control: InactivityTimeoutSecs registry value
- Test: read it with PowerShell
- Evidence: dated file / screenshot
- Finding: CONFORM or NON-CONFORM

The conformity-assessment chain (Lesson 1)



Non-conformity → corrective action (removes the cause) → verification (re-test) → audit trail keeps every step

Grading non-conformities

- Major — control absent or broken down (no backup at all)
- Minor — isolated lapse in a working control (1 laptop of 45)
- Observation — weakness or opportunity, not a failure
- Grading decides urgency and, for certification, the certificate

KEY TERM

Evidence

Records, statements of fact or other verifiable information produced by a test; it must be sufficient, reliable and relevant.

Conformity vs compliance

- Conformity — fulfilment of any requirement (ISO vocabulary)
- Compliance — fulfilment of mandatory external obligations
- Érable Cycles must comply with Law 25; it may conform to ISO 27001
- Same method for both: requirement, test, evidence, finding

KEY TERM

Finding

The result of evaluating evidence against a requirement: a conformity, a non-conformity or an observation.

Three objectives

- Determine — is each requirement fulfilled?
- Demonstrate — evidence another person can verify
- Enable decisions — correct, accept, certify
- An assessment that produces no decision has failed

KEY TERM

Non-conformity (major / minor)

Non-fulfilment of a requirement. Major = control absent or broken down; minor = isolated lapse in a working control.

Real-life example — Check-ScreenLock.ps1

REAL-LIFE EXAMPLE

- One requirement: screen lock ≤ 900 s
- Read the registry value, compare, write evidence, append the finding row
- Output = first row of the Lab 4 findings table
- Run on the Windows VM as Administrator

KEY TERM

Observation

A remark that is not a non-conformity but signals a weakness or an opportunity for improvement.

2

Lesson 2 — Why conformity assessment matters in cybersecurity management

Five concrete reasons an organization performs conformity assessments, illustrated with the obligations and penalties that apply to Érable Cycles.
≈ 8 minutes

Lesson 2 — Why it matters

- Due diligence — documented, dated proof
- Legal & financial exposure — five obligations at once
- Facts instead of opinions for risk management
- Customer and partner demand
- The improvement cycle

KEY TERM

Due diligence

The reasonable, documented steps a prudent organization takes to protect the information it holds; an assessment with dated evidence is the proof of it.

Érable Cycles — five obligations at once

- PIPEDA — collects personal information → OPC
- Law 25 — operates in Quebec → CAI
- GDPR — sells to EU residents → EU supervisory authority
- PCI DSS — accepts cards → acquiring bank (contract)
- CASL — newsletter → CRTC

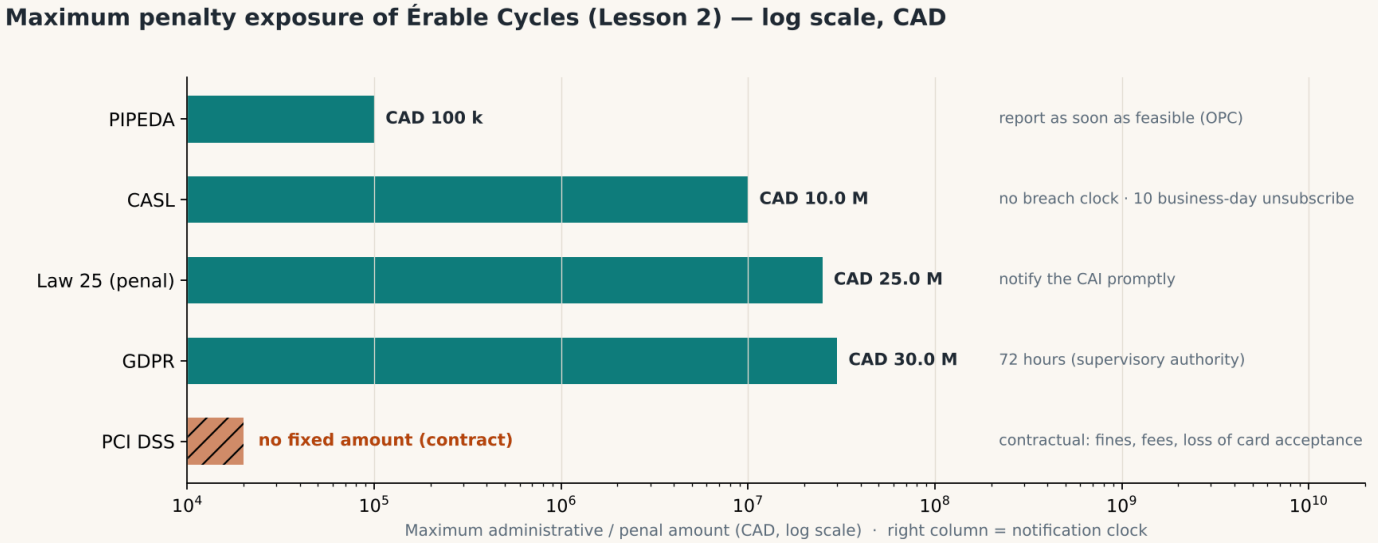
KEY TERM

Legal exposure

The penalties, orders and liabilities an organization faces when it does not meet a mandatory obligation (law, regulation, contract).

Exposure — penalties and clocks

- GDPR: EUR 20 M or 4 % · notify within 72 h
- Law 25: CAD 25 M or 4 % (penal) · notify promptly
- CASL: CAD 10 M per violation
- PIPEDA: CAD 100 k per offence · records 24 months
- PCI DSS: fines, fees, loss of card acceptance



Facts, customers, improvement

- “Our laptops are encrypted” is an opinion until tested
- Questionnaires, SAQ A, ISO certificate, SOC 2 report — all assessments
- Findings → actions → verification → next assessment
- Cost of assessing is known; cost of a discovered gap is not

KEY TERM

Regulator

The public body that enforces a law: OPC (PIPEDA), CAI (Law 25), CRTC (CASL), EU supervisory authorities (GDPR).

Real-life example — exposure_register.py

REAL-LIFE EXAMPLE

- Six company facts in, five obligations evaluated
- Output: register with enforcer, max penalty, deadline
- exposure_register.csv = skeleton of the Lab 1 register
- python3 exposure_register.py

KEY TERM

Contractual obligation

A requirement that binds through a contract rather than a law — PCI DSS through the merchant agreement with the acquiring bank.

3

Lesson 3 — Types of audits and assessments

Who performs an assessment, with what independence and what output — and the seven principles every auditor follows.
≈ 10 minutes

Lesson 3 — Types of audits

- Audit = systematic, independent, documented process (ISO 19011:2026)
- Objective evidence evaluated against audit criteria
- Classified by who performs it

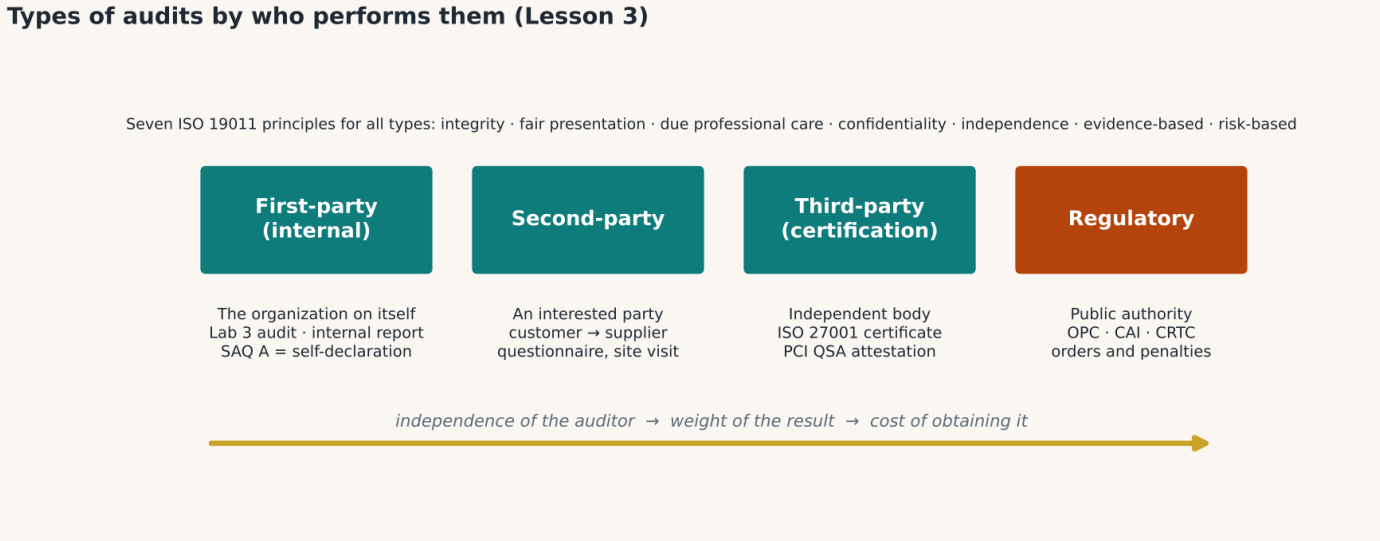
KEY TERM

Audit

Systematic, independent and documented process for obtaining objective evidence and evaluating it to determine the extent to which the audit criteria are fulfilled (ISO 19011).

First, second, third party — and regulators

- First-party (internal) — the organization on itself
- Second-party — an interested party (customer → supplier)
- Third-party — independent body (certification body, PCI QSA)
- Regulatory — public authority (OPC, CAI, CRTC): orders and penalties



Cyber.SoHo Educational Hub · 420-D04-AB · Day 1

Assessment, audit, attestation

- Assessment — the general act of examining conformity
- Audit — a formal assessment (systematic, independent, documented)
- Attestation — formal statement that requirements are fulfilled
- Declaration = by the organization (PCI SAQ); certification = by a third party (ISO 27001)
- Accreditation — attestation of the certifier's competence

KEY TERM

Second-party audit

Performed by an interested party, usually a customer auditing a supplier before or during a contract.

Point in time vs continuous

- Point-in-time: the state on the day of the test
- Continuous monitoring: automatic, repeated (Compliance Manager, Intune, AWS Config)
- Both are needed — the audit gives the formal result, monitoring keeps it true

KEY TERM

Third-party audit

Performed by an independent body with no stake in the result (certification body, PCI QSA); the result is a certificate or an attestation.

The seven audit principles (ISO 19011)

- Integrity · Fair presentation · Due professional care
- Confidentiality · Independence
- Evidence-based approach · Risk-based approach
- The lab ethics notice = these principles written as rules

KEY TERM

Regulatory audit

Performed by a public authority (OPC, CAI, CRTC); it can lead to binding orders and penalties.

Real-life example — audit_type_classifier.py

REAL-LIFE EXAMPLE

- Five situations, two questions: who? why?
- S1 internal · S2 customer · S3 SAQ self-declaration · S4 certification · S5 regulatory
- Your Lab 3 audit = S1, under the CEO mandate
- audit_types_reference.csv

KEY TERM

Attestation / declaration / certification

Attestation = formal statement that requirements are fulfilled; declaration = attestation by the organization itself; certification = attestation by a third party.

4

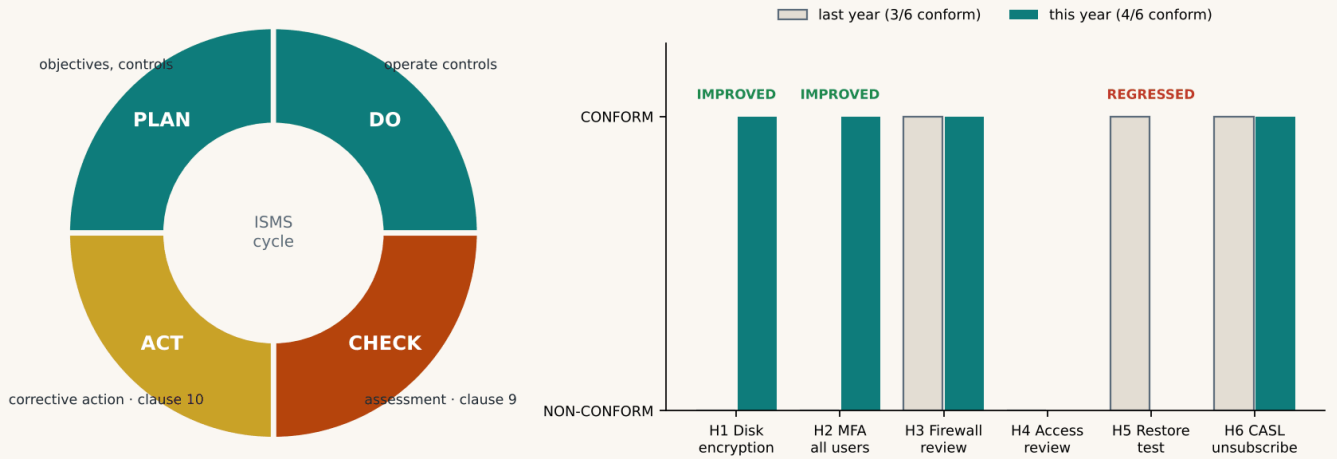
Lesson 4 — The role of conformity assessment in continuous improvement

What happens to findings after the audit: the PDCA cycle, ISO/IEC 27001 clauses 9 and 10, corrective actions and the comparison with historical results.
≈ 8 minutes

Lesson 4 — Continuous improvement

- PDCA: Plan → Do → Check → Act
- The conformity assessment is the Check step
- Every management-system standard is built on this cycle

PDCA and the year-over-year comparison of the six historical items (Lesson 4)



Cyber.SoHo Educational Hub · 420-D04-AB · Day 1

ISO/IEC 27001:2022 — clause 9

- 9.1 Monitoring, measurement, analysis, evaluation
- 9.2 Internal audit — planned intervals, objective auditors, audit programme
- 9.3 Management review — top management examines results and decides

KEY TERM

ISO/IEC 27001 clause 9 — Performance evaluation

9.1 monitoring, measurement, analysis and evaluation; 9.2 internal audit at planned intervals by objective auditors; 9.3 management review by top management.

ISO/IEC 27001:2022 — clause 10

- 10.1 Continual improvement
- 10.2 Nonconformity and corrective action:
- react → find the cause → act → review effectiveness → update → document
- Correction (fix the instance) ≠ corrective action (remove the cause)

KEY TERM

ISO/IEC 27001 clause 10 — Improvement

10.1 continual improvement; 10.2 nonconformity and corrective action (react, find the cause, act, review effectiveness, update, document).

Comparison with historical data (EZ04 5.1)

- Same items, next assessment: improved / unchanged / regressed
- Regression = a process failure, not a technical one
- Conformity rate per domain = conform ÷ tested
- Case file: six items from last year

KEY TERM

Root cause

The underlying reason a nonconformity occurred; removing it prevents recurrence.

Verification closes the loop

- An action is finished when a re-test proves the requirement fulfilled
- Follow-up plan: verification method + re-test date (CIS-CAT Lite / Lynis in 30 days)
- Continuous monitoring automates part of it between audits

KEY TERM

Correction vs corrective action

Correction fixes the instance (encrypt one laptop); corrective action removes the cause (enforce encryption for all deployments).

Real-life example — trend_compare.py

REAL-LIFE EXAMPLE

- Six items × two years → trends and rates per domain
- Two improvements, one regression, one unchanged non-conformity
- corrective_action_register.csv: owner, due date, re-test date
- First rows of Project Section 8

KEY TERM

Verification of effectiveness

A re-test proving the requirement is now fulfilled; a corrective action is finished only when verified.

5

Lesson 5 — Steps in designing and developing an assessment plan

The six-step method the whole course follows, what an assessment plan contains, and how the plan maps onto the five labs and the Project.
≈ 10 minutes

Lesson 5 — Designing the assessment plan

- ISO 19011 lifecycle: initiate → prepare → conduct → report → complete → follow up
- The course compresses it into six steps
- Applied once, end to end, on Érable Cycles

KEY TERM

Assessment plan

The approved document stating what will be assessed, against which requirements, by whom, how, when and with what resources — before any test runs.

Steps 1–3

- 1 Identify requirements → applicability register, frameworks (Lab 1)
- 2 Define scope, inventory assets, critical assets (Lab 2)
- 3 Build the plan: scope statement, mandate, checklist, tests, 3×3 risk matrix, schedule (Lab 3)

KEY TERM

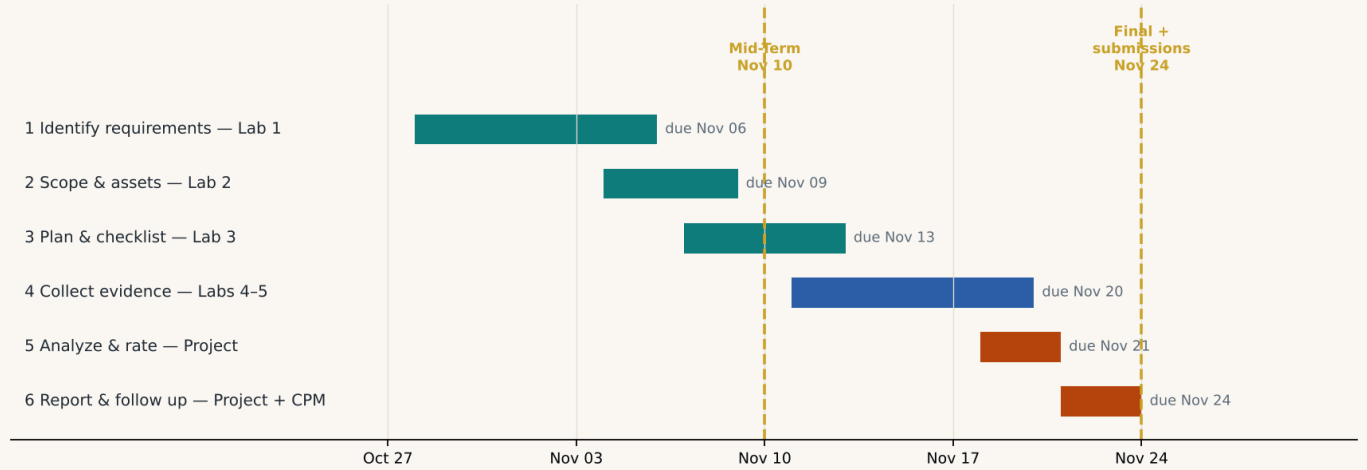
Applicability register

Table of laws, contracts, standards and policies with Applies? / reason / enforcer / key obligations / consequences (Step 1, Lab 1).

Steps 4–6

- 4 Collect evidence: configuration audits (Lab 4) + controls verification (Lab 5)
- 5 Analyze, rate with the matrix, prioritize — 30-60-90 plan (Project)
- 6 Report, communicate, follow up — corrective-action register (Project + CPM)

The six steps of the assessment method on the CYB-01 calendar (Lesson 5)



Cyber.SoHo Educational Hub · 420-D04-AB · Day 1

What a good plan looks like

- Short, specific, approved before the first test
- Sample sizes stated (10 of 45 laptops)
- Evidence to keep named for each test
- Changes during the assessment are re-approved

KEY TERM

Scope statement and mandate

What is in and out of the assessment, and the signed authorization that gives the legal basis for every test (Step 3, Lab 3).

Real-life example — plan_builder.py

REAL-LIFE EXAMPLE

- Six steps on the real calendar: owner, tools, output
- Checklist skeleton: 7 columns, 3 example items
- assessment_schedule.csv + checklist_skeleton.csv
- Lab 3 replaces the 3 examples by 12–15 Master Checklist items

KEY TERM

Checklist

One line per item: ID, framework reference, requirement text, test procedure, sample, expected evidence, result.

6

Lesson 6 — The case company, the tool map and what Lab 0 will do

Érable Cycles in one page, the student tools versus the instructor-demo tools, the lab environment, and the summary of tonight's Lab 0.
≈ 9 minutes

Lesson 6 — The case company

- Érable Cycles inc. — Montréal, Laval, Québec City; 45 employees; Canada, USA, EU
- Data: customer accounts, newsletter (≈ 18,000); no card numbers stored
- Systems: Windows Server 2022, pfSense (3 VLANs + guest Wi-Fi), 45 Windows 11 laptops, NAS, Microsoft 365, AWS web store
- People: 1 IT admin, an MSP, the CEO in charge of PI

KEY TERM

Case file

The one-page description of Érable Cycles (facts, policies, firewall rules, zone diagram, access-review extract, last year's six results) used in every lab.

Your role and the case file

- Junior conformity analyst under a written CEO mandate
- Report without blame; keep results confidential; stay inside the VMs and the case file
- Case file: 6 policies, firewall-rule table, zone diagram, access-review extract, last year’s 6 results

KEY TERM

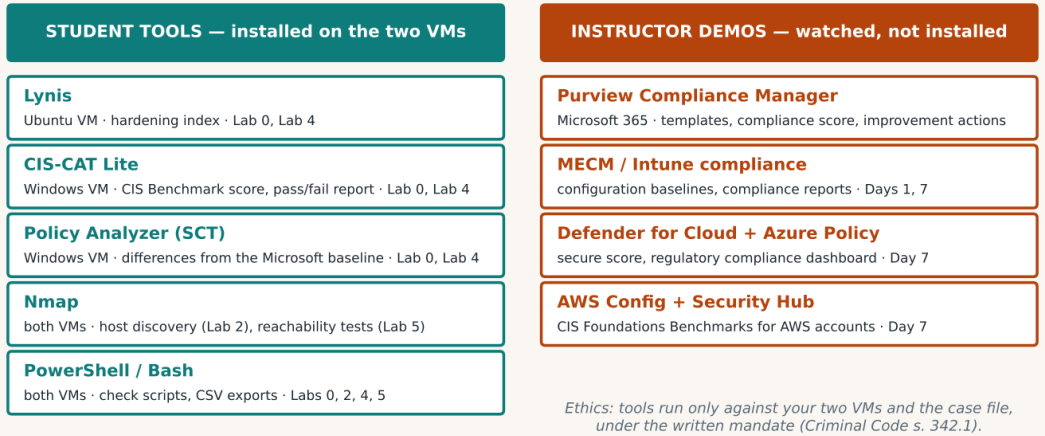
Junior conformity analyst

Your role: tests under a written mandate, reports without blame, keeps results confidential, stays inside the two VMs and the case file.

Tool map — student tools (free)

- Lynis — Linux hardening index (Ubuntu VM)
- CIS-CAT Lite — CIS Benchmark score, pass/fail report (Windows VM)
- Policy Analyzer — differences from the Microsoft baseline (Windows VM)
- Nmap — host discovery, reachability tests
- PowerShell / Bash — the check scripts

Tool map of the course (Lesson 6)



Tool map — instructor demos

- Microsoft Purview Compliance Manager — templates, score, improvement actions
- MECM compliance settings / Intune compliance policies — baselines and reports
- Microsoft Defender for Cloud + Azure Policy
- AWS Config + Security Hub (CIS Foundations Benchmarks)
- Watched, never installed by students

KEY TERM

CIS-CAT Lite

Free CIS Benchmark assessor for Windows 10/11 Enterprise (and some other products); HTML report with pass/fail per recommendation and a score.

Lab environment

- VM 1: Windows 11 Enterprise 90-day evaluation — 26H2 or LTSC 2024 (Enterprise = benchmark detected)
- VM 2: Ubuntu LTS 24.04.5 or 26.04.1 (Lynis works on any release)
- CyberQuébec range when provisioned, otherwise VirtualBox / VMware Workstation
- First action: snapshot named “clean”
- Evidence naming: L4-F03_cis-cat_report.html

KEY TERM

Policy Analyzer

Microsoft Security Compliance Toolkit tool that compares local policy with the Microsoft security baseline and lists the differences.

Real-life example — verify_tools.sh / Verify-Tools.ps1

- Requirement: tool installed → test: version command → evidence: CSV row + screenshot → finding: FOUND / MISSING
- Ubuntu: OS, Lynis, Nmap, Bash
- Windows: OS build, PowerShell, Get-HotFix, CIS-CAT Lite, Policy Analyzer
- Output = Environment checklist (Lab 0 → CPM Chapter 0)

KEY TERM

Nmap

Network discovery and port-reachability tool used for host discovery (Lab 2) and segmentation tests (Lab 5).

Lab 0 tonight — summary

- Snapshots of both VMs
- Ubuntu: apt install lynis nmap; lynis audit system (note the index)
- Windows: CIS-CAT Lite + Security Compliance Toolkit; Policy Analyzer baseline; Get-ComputerInfo / Get-HotFix
- Watch the Purview and MECM/Intune demos
- Deliverable: half-page Environment checklist — ungraded, required, Omnivox LÉA before Day 7

KEY TERM

Instructor-demo tools

Purview Compliance Manager, MECM/Intune compliance baselines, Defender for Cloud, AWS Config/Security Hub — shown, never installed by students.

Lab 0 tonight — what you will do

- Confirm access to both lab VMs (Windows 11 Enterprise 90-day evaluation — the Windows 10 evaluation is no longer offered — and Ubuntu LTS) and take a clean snapshot of each before anything is installed.
- Ubuntu VM: install Lynis and Nmap with sudo apt update && sudo apt install -y lynis nmap, run sudo lynis audit system once and write down the hardening index (first look only — no analysis tonight). On Ubuntu 24.04 the apt package is Lynis 3.0.9; the CISOfy repository or a git clone gives the current 3.1.7.
- Windows VM: download and unzip CIS-CAT Lite (free registration on the CIS site), start the Assessor and confirm that the Windows benchmark is detected; download the Microsoft Security Compliance Toolkit, open Policy Analyzer and load the Windows 11 baseline; verify PowerShell with Get-ComputerInfo and Get-HotFix.
- Watch (do not install) the two instructor demos: Microsoft Purview Compliance Manager and MECM / Intune compliance baselines.
- Deliverable: the half-page Environment checklist (tool · version · VM · screenshot) built with the two verification scripts from Lesson 6 — it becomes Chapter 0 — Lab environment & tools of the Course Procedure Manual.

Recall points for Day 2

- The ISO/IEC 17000 definition and the chain requirement → control → test → evidence → finding
- The four audit types and the seven ISO 19011 principles
- PDCA; ISO/IEC 27001 clauses 9 and 10
- The six steps and which lab performs each
- Which tool does what

Official links

- Laws: OPC · CAI · CRTC · PCI SSC · EUR-Lex (GDPR)
- Standards: NIST CSF 2.0 · ISO/IEC 27001 · ISO 19011 · ISO/IEC 17000 · CIS Controls & Benchmarks
- Tools: CIS-CAT Lite · Lynis · Security Compliance Toolkit · Nmap · Evaluation Center · Ubuntu · VirtualBox
- All links, with explanations, are in the lecture HTML (Links section)

Questions — then Lab 0

Questions on the six lessons
Break 19:30–19:45
Lab 0 starts at 19:45: snapshot first, then tools
Environment checklist → Omnivox LÉA DropBox before Day 7